

Laporan Bulan Agustus dan Billing — SpringHub

Periode: 1 – 25 Agustus 2026 **Proyek:** SpringHub — Jaga Semesta **Penyusun:** Ayatullah Reza — Full-stack Developer

Bagian 1 — Hardening & Staging (1-14 Agustus)

Ringkasan

Fokus mengunci input, menutup XSS, dan menstabilkan staging agar produksi bisa diuji tanpa takut data hilang. Staging paralel di VPS di-restore dari dump produksi dan diuji 205 test manual.

Input & XSS

Area	Detail
83 field lib/forms.ts	.max(500) (cerita 5000) — cegah payload raksasa
DOMPurify 2 lapis app/api/courses/[slug]/route.ts	jsdom tidak masuk bundle client (serverComponentsExternalPackages), <script>onerror/javascript: bersih
Bug	lib/sanitize.ts syntax, await di luar async (queue-worker), nginx-staging server_name
Test	37/37 hijau (vitest), secrets scan bersih
Seed guard	prisma/seed.ts hanya jalan di DB kosong, wajib SEED_FORCE=1

Staging Paralel

- Stack docker-compose.staging.yml (DB springhub_staging 5433, Redis 6380, web 31760, nginx 8080 basic auth)
- Restore backups/springhub-20260812-0513.dump , baseline 10 migrasi, fix-orphan-reports 0 klaster, health OK

Audit Foto & Hardening (14 Agu, via staging)

Temuan	Perbaikan
Foto: Blob type kosong, PHOTOS_PENDING drop, N+1	QueueWorker serverReportId + retry 30s, clientCorrelationId + uploadPhotoWithCsrf, foto admin sekaligus + badge ⚠️ 0 foto
PII bocor 3 rute	map-points/[id], projects/[id], seedlings/[id] → phone admin-only, approved filter
CSRF 14 route	verifyCsrfToken() ke photos/reports/projects/notifications/offline/courses/profile/admin
Lain	approve-all transaction, escapeHtml email, getClientIp, middleware api/admin/* + CSP unsafe-eval hapus

Bagian 2 — Security Hardening & Deploy Produksi (19-25 Agustus)

Ringkasan

Produksi di-patch CVE, CSRF di auth, dan data Epicollect diaktifkan. Dikerjakan **staging dulu, produksi setelah ACC**.

Data Epicollect

- 199 report + 551 foto** (23×1 + 176×3) public/form-1__*.json → clientCorrelationId = ec5_uuid

- Staging: 199/199 approved, 189 spring active (total 261) — 23 report 1-foto sempat di-approve lalu **di-revert total**
- **Aktivasi 24-25 Agu:** backup 12M/5.4M, scripts/activate-staging-data.ts approve 4 pending + aktifkan **8 data asli** (Sumber Telaga, Belik Soka, Sumber Gempol, Sumber Taman, Randu Alas 46 reports, Sumber Brantas, Sumber Maron, Mata Air Kalibayem) — skip 5 kosong + 24 dummy. Hasil: staging **261→269** (160 groups), produksi **73→81** (81 groups). Backfill scripts/backfill-epicollect-photos.ts dry-run **0 perlu** (551/551 lengkap).

CVE & Auth

Area	Detail
CVE-2025-29927	Next 14.2.5→14.2.35 (lalu 15.5.23 di P1) + blok x-middleware-subrequest middleware.ts:56
CSRF auth	6 route + 5 halaman (sign-in/join/forgot/reset/logout) just-in-time fetch("/api/csrf")
Deps	sharp 0.35.3, jose 6.2.9, prisma 7.9.1, noeviction, image-worker fix

P0-P2 Hardening (24-25 Agu, 26 temuan, 1 per 1)

P0 KRITIS — commit c7765a5 :

- DB prod ghost 20260603_add_comments NULL → hapus, PasswordResetToken + 3 index, Donation.invoiceId '' → inv-* + UNIQUE + 5 index, RLS 8 policy Report / Profile , clientCorrelationId manual → form 503 → 200
- Login app/api/auth/login/route.ts:56 lockout enforce sebelum bcrypt → 429
- CSRF lib/csrf.ts:33 verifyJwtWithRotation + lib/auth.ts:8 hapus cache
- Middleware has("x-middleware-subrequest")
- Secrets .env.example:54 → CHANGE_ME_STRONG_RANDOM

P1 HIGH — 71585ab , 7f3d2fb , c7ccc2d , ae68878 :

- PII hapus email springs/[id]:72 & projects/[id]:15 ,leak springs/bulk:33 tambah status:"active"
- Rate-limit 7 route → dashboard , springs/[id] , gallery , map-points , seedlings , notifications (POST admin-only), user/profile , offline/session , courses + Next 15.5.23 (2 advisory DoS → 0)

P2 PWA — f97c726 , 497a40d , 66eb817 :

- use-auto-save draftId mismatch + interval, BlobPreview 5 file revoke leak, site-header clearAllofflineUserData , queue-worker MAX_RETRIES 3→20 ,compose DATABASE_URL pool + image:springhub-web , lib/sanitize.ts:10 g flag, app/springs/[id]:494 alt foto, lib/i18n.tsx:44 flash
- **Manual test** MANUAL-TEST-FINAL.md 188→205 test (24 kategori, +17 Test 24 Full Data Flow) dan **deploy produksi** docker compose build web Next 15 → healthy

Bagian 3 — Kendala: Xendit & Donasi

Fitur donasi menggunakan Xendit sebagai payment gateway. Backend untuk invoice dan webhook sudah selesai 100%. Namun terkendala:

1. **XENDIT_SECRET_KEY** masih kosong — perlu didapatkan dari dashboard akun Xendit
2. **XENDIT_WEBHOOK_TOKEN** masih kosong — perlu dibuat di dashboard Xendit
3. **Akun Xendit** belum dibuat oleh client

Komponen	Status
POST /api/donations/invoice	✅ Backend siap (butuh XENDIT_SECRET_KEY)
POST /api/donations/webhook	✅ Backend siap (butuh XENDIT_WEBHOOK_TOKEN)
Validasi HMAC	✅ Siap

Konfigurasi env	✖ Kedua key kosong
-----------------	--------------------

Bagian 4 — Billing

Item	Detail
Nama	Ayatullah Reza Chalid
Peran	Full-stack Developer SpringHub
Periode	24 Juni 2026 — 30 Juli 2026
Total	Rp2.500.000 (Dua Juta Lima Ratus Ribu Rupiah)

Bank Tujuan Pembayaran

Penerima	Ayatullah Reza Chalid
Bank	BANK BRI
Nomor Rekening	359001035332531

Terima kasih atas kerjasamanya. SpringHub — Jaga Semesta